

# Unauthorised Internal Database Access response

Intrusion · **High** severity · SOC IR Playbook

|                   |                                                                                                 |
|-------------------|-------------------------------------------------------------------------------------------------|
| Incident type     | Access Control Violation - Data Access Abuse                                                    |
| Severity          | High                                                                                            |
| Priority          | Critical                                                                                        |
| Detection sources | SIEM, Database Activity Monitoring (DAM), User Behaviour Analytics (UBA), EDR, Application Logs |

## Scenario

An insider or compromised system accesses database resources in an unauthorised manner, such as bypassing access controls, querying sensitive tables or using privileged database accounts inappropriately. This may include data snooping, unauthorised exports or lateral movement toward database servers.

## MITRE ATT&CK

T1071.001, T1078, T1213.003

## Preparation

Implement database activity monitoring Use tools like Imperva DAM, IBM Guardium or native audit logs Restrict access using least privilege Use role-based access and limit direct DB access Enable logging and alerts Log all privileged queries, schema access and authentication events Regularly review database roles and privileges Audit permissions for all database users and service accounts Encrypt sensitive data Protect high-value fields (e.g., PII, passwords) at rest and in transit

## Detection & Analysis

Receive alert from DAM or SIEM Unusual query volumes, direct table scans or after-hours access Correlate with user behaviour Review user's historical database access patterns Examine queries or transactions Determine what data was accessed, modified or exported Check for lateral movement See if access followed endpoint or network compromise

## Containment

Revoke database access Disable or suspend the offending account or connection Isolate compromised endpoint If access came from a breached host Block outbound data transfer Via DLP, firewall or proxy if exfiltration is suspected Notify data owners and IT security Involve stakeholders for immediate containment decisions

## Eradication

Reset credentials or tokens For database accounts that were abused Remove rogue users or permissions Audit database for hidden users, triggers or escalated privileges Patch vulnerabilities If a flaw in application or database was exploited Clean up logs Archive and secure logs for forensic investigation before removal or trimming

## Recovery

Restore legitimate access After proper revalidation of user roles Monitor for repeat access Apply enhanced monitoring for the same user or host Perform integrity check Validate that no data was altered or corrupted during the incident Resume services Resume application or database operations once secure and validated

## Lessons Learned & Reporting

Conduct post-incident analysis Understand whether this was malicious, accidental or systemic Enhance database monitoring rules Add new patterns and alert conditions Train users and DB admins Reinforce data access policies and logging expectations Report data exposure If required by law or policy (e.g., PDPA, GDPR, PCI DSS) Update runbooks Include playbook refinements and lessons learned in SOC documentation

### ***Tools typically involved***

SIEM (e.g., Splunk, Sentinel, QRadar); Database Activity Monitoring (e.g., Imperva, IBM Guardium, AWS RDS Logs); User Behaviour Analytics (e.g., Exabeam, Securonix); EDR (if endpoint is involved); Application logs (e.g., from middleware or APIs calling the database); DLP and network proxy (to detect potential exfiltration)

### ***Success metrics (SLA targets)***

Detection Time <5 minutes from unauthorised access Containment Time <30 minutes from confirmation Forensic Review Completion Within 48 hours Role/Permission Audit Completion Within 7 days Policy Update and Revalidation Within 2 weeks